



HUTECH

Đại học Công nghệ Tp.HCM

KHOA CÔNG NGHỆ THÔNG TIN

Học phần: BẢO MẬT THÔNG TIN

Nhóm F3

ĐỀ TÀI NHÓM :

Ứng dụng chat LAN bảo mật AES
- phòng chống tấn công Man-in-the-Middle (MITM)

GVHD : ThS. Phan Đình Duy Thông

GIỚI THIỆU THÀNH VIÊN :

Phùng Ngọc Bảo

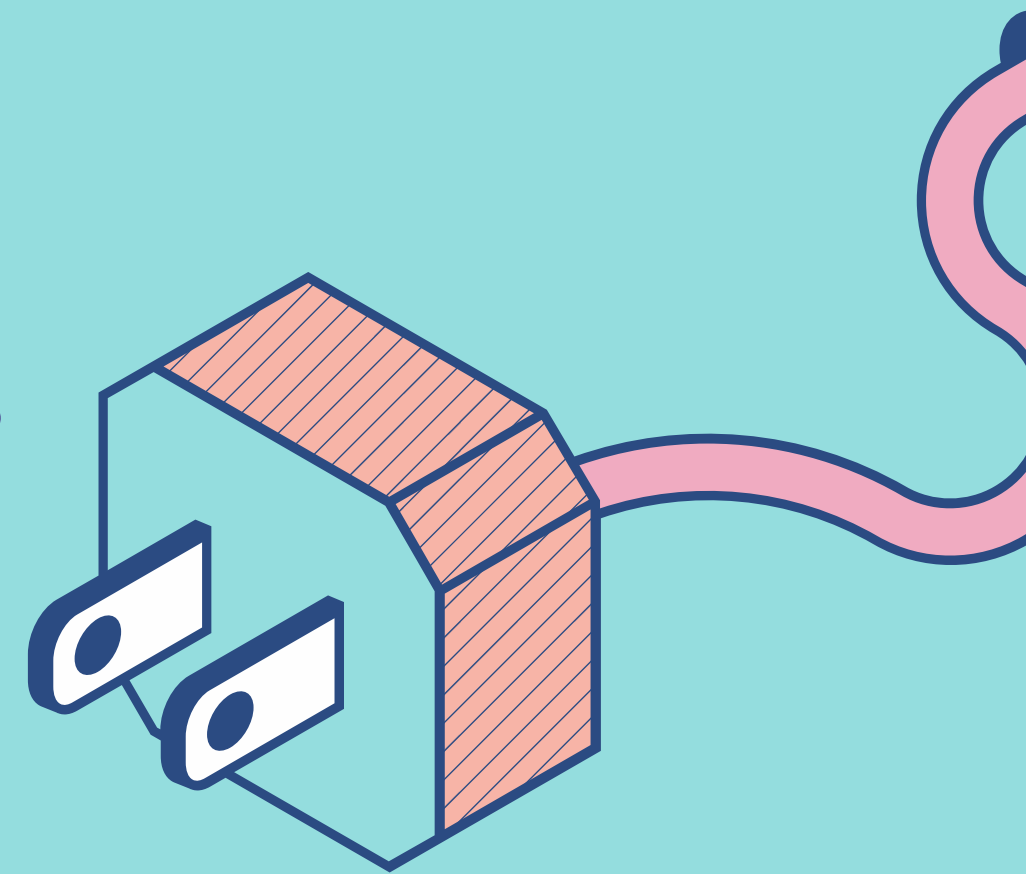
MSSV : 2380600168

Lê Phan Tiến Nam

MSSV : 2380604608

Võ Minh Nghĩa

MSSV : 2380601458



1. Giới thiệu đề tài

Tên đề tài: Xây dựng ứng dụng Chat trong mạng LAN bảo mật bằng thuật toán AES và mô phỏng phòng chống tấn công nghe lén (MITM).

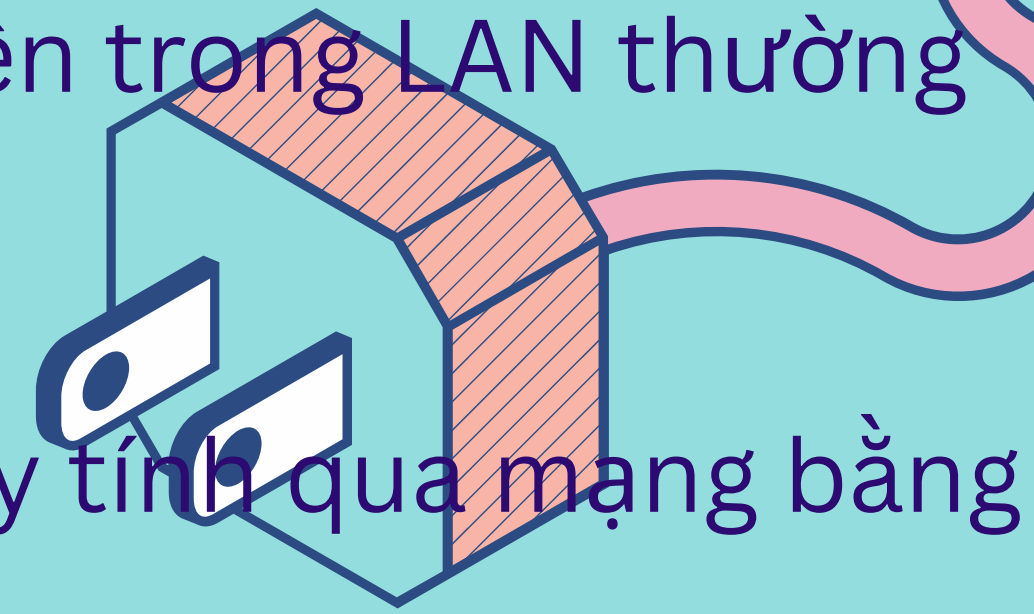
Mục tiêu: Tạo ra một môi trường giao tiếp an toàn, nơi nội dung tin nhắn được bảo vệ ngay cả khi đường truyền bị kiểm soát bởi bên thứ ba.



1. Lý thuyết nền tảng - An toàn mạng LAN & Socket



Khái niệm mạng LAN (Local Area Network): Mạng nội bộ cho phép các thiết bị kết nối và chia sẻ tài nguyên. Tuy nhiên, dữ liệu truyền trong LAN thường ở dạng không mã hóa, dễ bị đánh cắp.



Lập trình Socket: Là phương thức giao tiếp giữa hai máy tính qua mạng bằng cách sử dụng các điểm cuối (End-points).

TCP/IP: Giao thức tin cậy được sử dụng trong đồ án để đảm bảo dữ liệu không bị mất mát khi chat.

2. Tổng quan về Mã hóa dữ liệu (Cryptography)



Khái niệm: Là quá trình chuyển đổi thông tin từ dạng có thể đọc được (Plaintext) sang dạng không thể đọc được (Ciphertext).

Phân loại:

Mã hóa đối xứng (Symmetric Encryption): Sử dụng cùng một khóa để mã hóa và giải mã (AES là tiêu biểu).

Mã hóa bất đối xứng (Asymmetric Encryption): Sử dụng cặp khóa Public và Private (RSA).

Tầm quan trọng: Đảm bảo tính riêng tư (Confidentiality) và tính toàn vẹn (Integrity) của thông tin.



3. Thuật toán mã hóa AES (Advanced Encryption Standard)



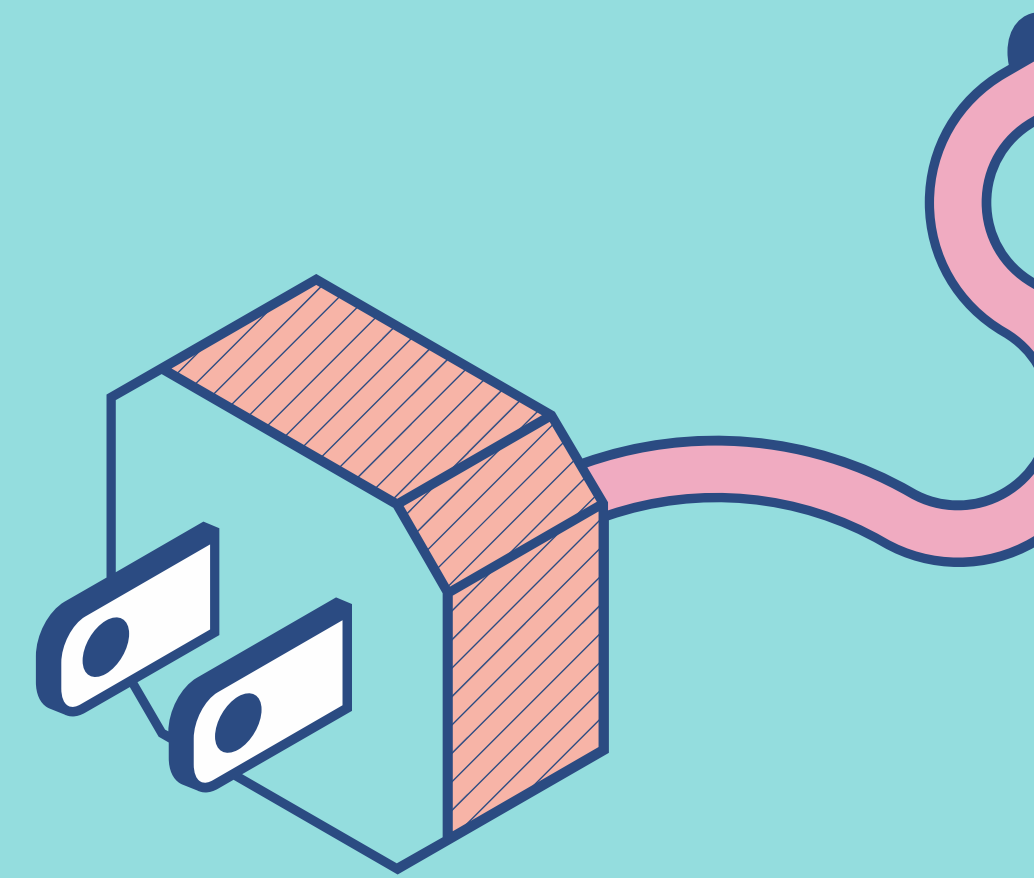
Lịch sử hình thành: Được Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ (NIST) phê duyệt năm 2001 thay thế cho chuẩn DES đã lỗi thời.

Cấu trúc kỹ thuật:
Sử dụng mã hóa khối (Block Cipher).

Kích thước khối cố định: 128 bit.

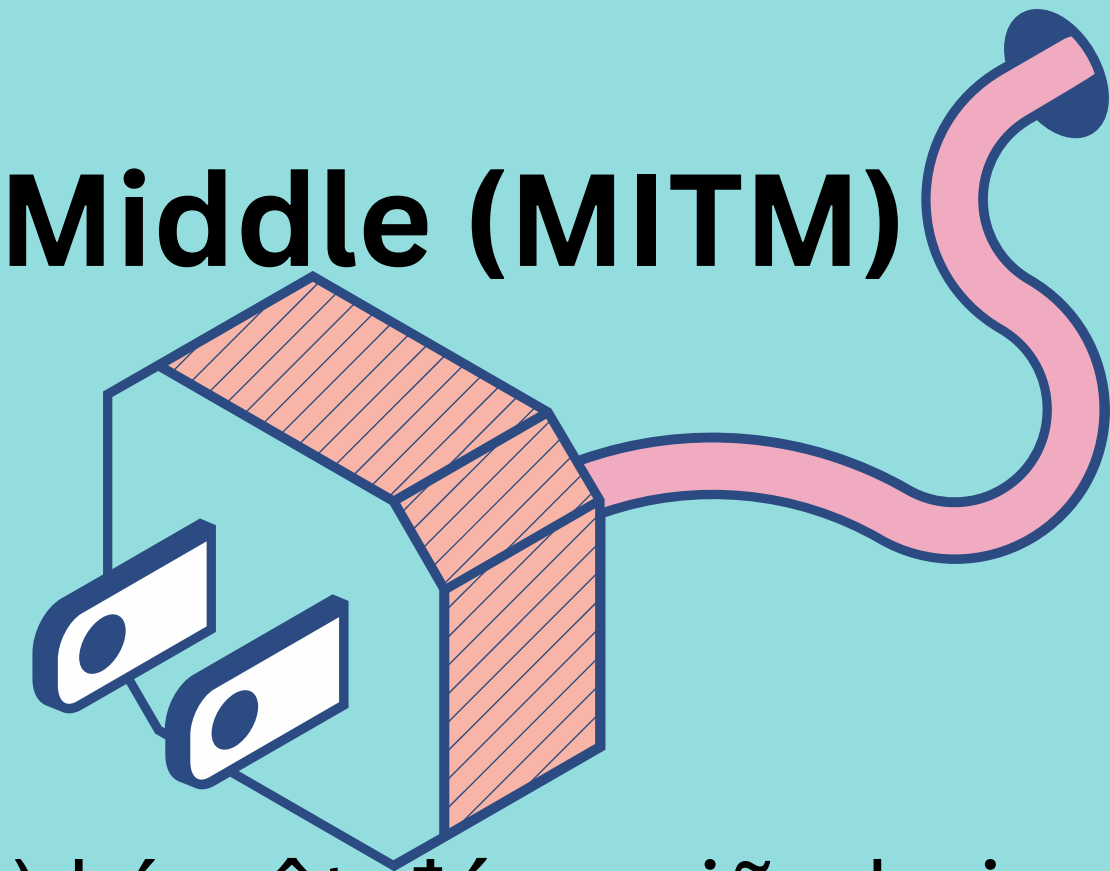
Độ dài khóa: 128, 192 hoặc 256 bit (Đồ án sử dụng AES-128).

Ưu điểm: Tốc độ xử lý cực nhanh, chiếm ít bộ nhớ và độ an toàn được chứng minh toàn cầu.





4. Khái niệm về Tấn công Man-in-the-Middle (MITM)



Định nghĩa: MITM là dạng tấn công mà kẻ tấn công (Attacker) bí mật đứng giữa hai bên đang liên lạc để nghe lén, chỉnh sửa hoặc đánh cắp dữ liệu.

Lịch sử: Xuất hiện từ thời sơ khai của mạng viễn thông, ngày nay biến tướng qua các kỹ thuật như ARP Spoofing, DNS Hijacking.

Tác hại: Rò rỉ thông tin nhạy cảm (mật khẩu, tài khoản ngân hàng), giả mạo danh tính.

5. Các biến thể và Hình thức tấn công MITM



Sniffing (Nghe lén): Thu thập các gói tin di chuyển trong mạng. (Đây là hình thức đồ án mô phỏng qua cổng 9999).

Packet Injection (Chèn gói tin): Kẻ tấn công chèn dữ liệu độc hại vào luồng chat.

Session Hijacking (Cướp phiên): Đánh cắp ID phiên đăng nhập của người dùng.

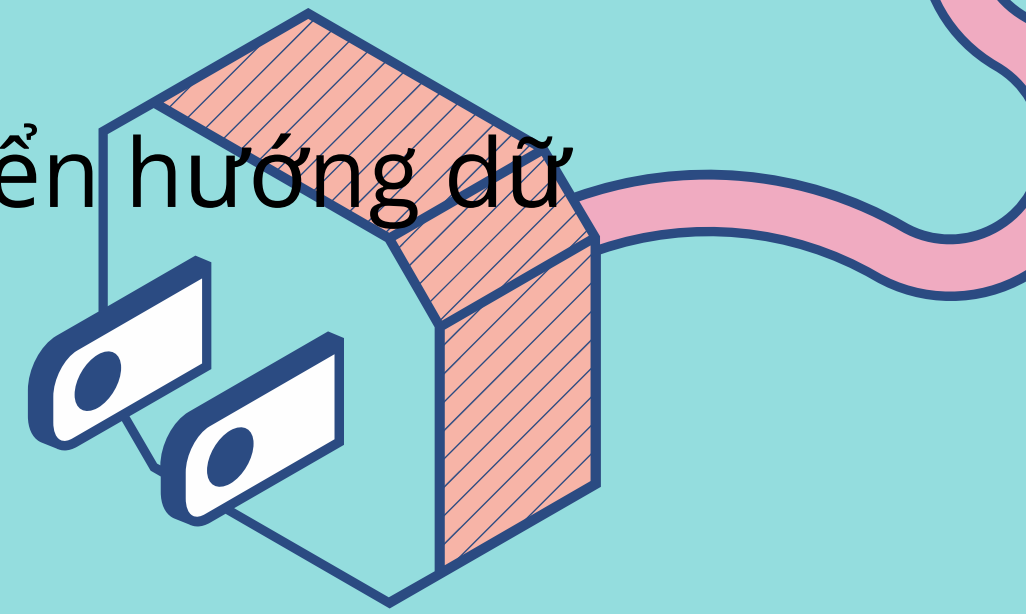
SSL/HTTPS Stripping: Hạ cấp kết nối bảo mật xuống không bảo mật để dễ dàng đọc dữ liệu.

6. Quy trình thực hiện một cuộc tấn công MITM (Mô phỏng)



Giai đoạn Thăm dò (Reconnaissance): Kẻ tấn công quét mạng LAN để tìm IP/Port của các máy đang giao tiếp.

Giai đoạn Đánh chặn (Interception): Sử dụng kỹ thuật chuyển hướng dữ liệu đi qua máy của kẻ tấn công.



Giai đoạn Khai thác (Exploitation): Đọc nội dung gói tin.

Nếu không mã hóa: Kẻ tấn công đọc được tin nhắn rõ ràng.

Nếu có AES: Kẻ tấn công chỉ thấy các ký tự rác.



7. Phương thức phòng chống tấn công MITM



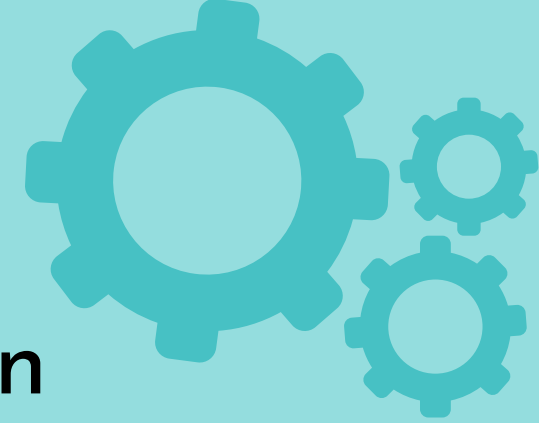
Mã hóa dữ liệu (Encryption): Giải pháp cốt lõi của đề án. AES giúp dữ liệu trở nên vô nghĩa nếu bị đánh cắp.

Sử dụng VPN: Tạo đường ống mã hóa riêng biệt.

Chứng chỉ số (SSL/TLS): Xác thực danh tính các bên tham gia.

Kiểm soát truy cập mạng: Giám sát các thiết bị lạ kết nối vào mạng LAN (Server ¹⁰ trong đề án có chức năng cảnh báo kết nối Sniffer).

8. Kiến trúc giải pháp bảo mật



2.1. Cơ chế mã hóa AES (Advanced Encryption Standard)

Sử dụng mã hóa đối xứng AES để mã hóa toàn bộ nội dung tin nhắn trước khi gửi đi.

Quy trình: Tin nhắn văn bản (Plaintext) → Mã hóa AES → Chuỗi mã hóa (Ciphertext) → Truyền qua mạng → Giải mã AES → Tin nhắn gốc.

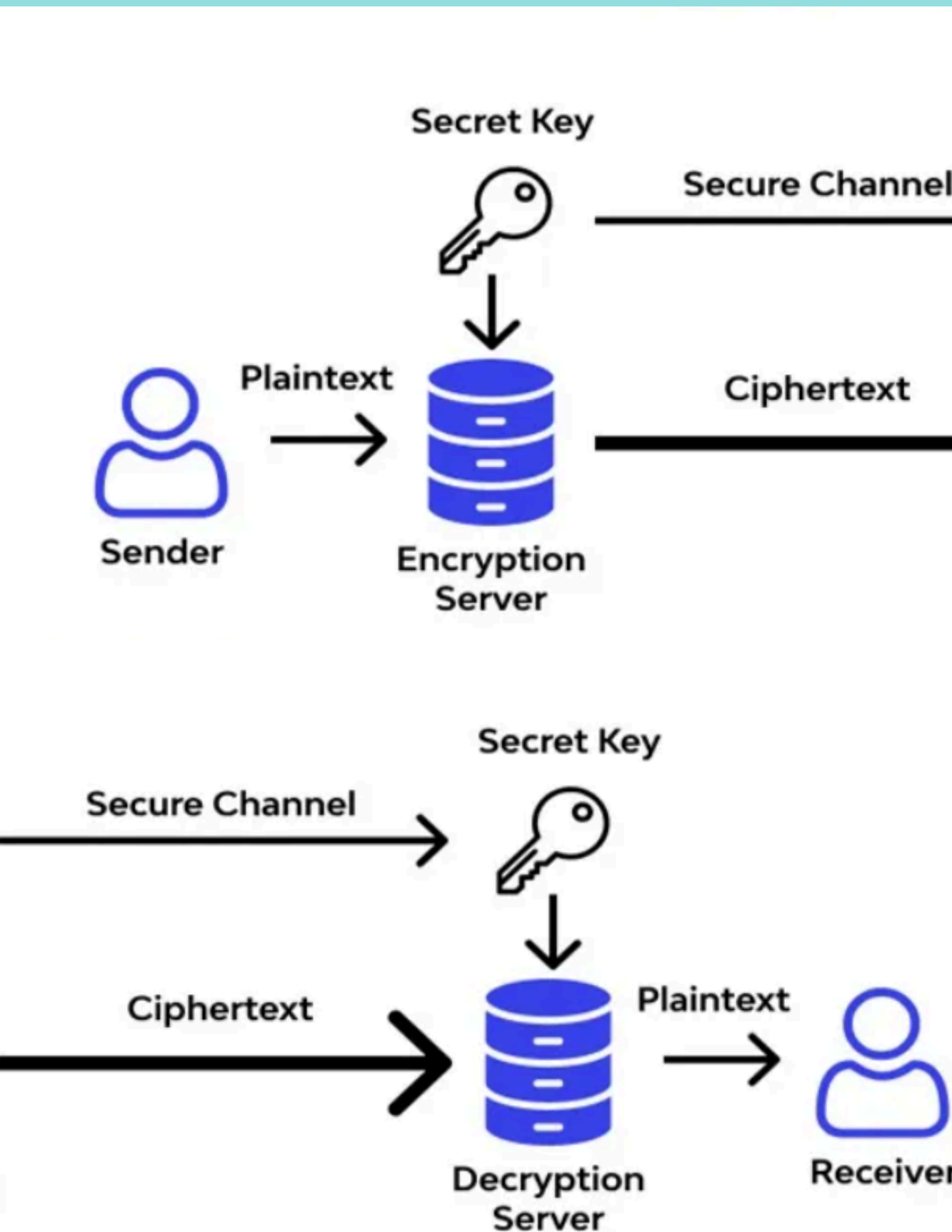
2.2. Mô hình hoạt động của Server

Cổng dịch vụ (Port 5000): Dành cho các Client hợp lệ kết nối để trao đổi dữ liệu.

Cổng Sniffer (Port 9999): Dành cho kẻ tấn công (Attacker) kết nối để thực hiện hành vi nghe lén.



9. Quy trình xử lý dữ liệu an toàn



Bước 1: Client nhập tin nhắn -> Mã hóa AES tại máy Client.

Bước 2: Gửi chuỗi đã mã hóa lên Server.

Bước 3: Server nhận dữ liệu (Ciphertext) -> Chuyển hướng một bản sao cho Sniffer.

Bước 4: Server giải mã để xử lý logic (nếu cần) rồi lại mã hóa để gửi tới người nhận

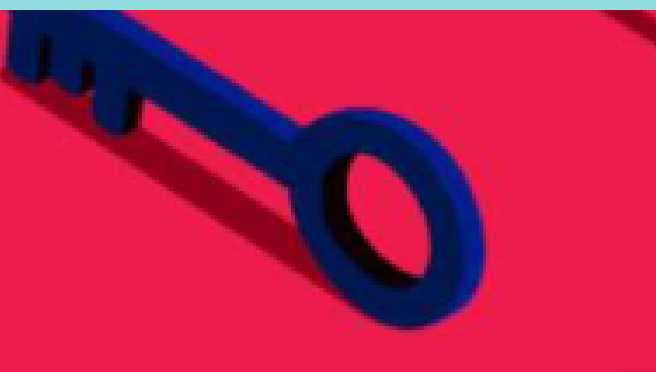
10. Phân tích tính năng "Sniffer" trong đồ án



Điểm đặc biệt của đồ án này là khả năng mô phỏng thực tế cuộc tấn công nghe lén để chứng minh sức mạnh của mã hóa:

Cơ chế đánh chặn: Trong lớp ClientHandler, ngay khi nhận được gói tin từ Client, Server sẽ gọi hàm notifyAttackers(line) để đẩy dữ liệu đó tới kẻ tấn công trước khi thực hiện giải mã.

Dữ liệu thu được: Kẻ tấn công kết nối qua cổng 9999 sẽ liên tục nhận được các gói tin. Tuy nhiên, vì dữ liệu đã được mã hóa AES ngay từ phía Client, kẻ tấn công chỉ thấy các chuỗi ký tự vô nghĩa (Ciphertext).



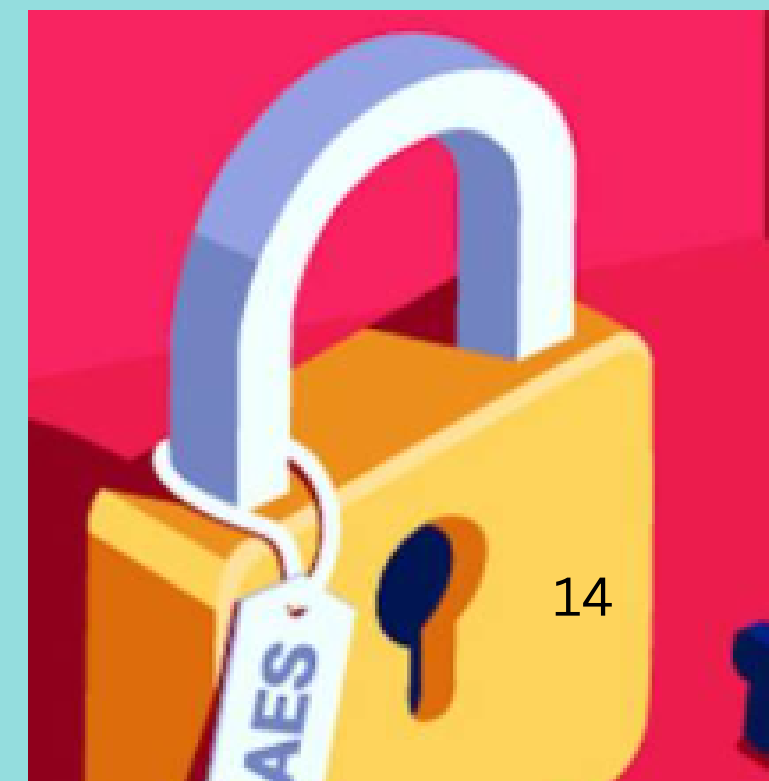
11 .Các tính năng nổi bật của ứng dụng

Xác thực: Đăng ký/Đăng nhập (Lưu trữ bằng Serialization).

Giao tiếp: Chat cộng đồng, Chat riêng, Chat nhóm.

Giải trí: Hệ thống Quiz đa người chơi (Real-time).

Đa phương tiện: Gửi File và Sticker.



12. Các đặc điểm của hệ thống

1. Tính bảo mật (Confidentiality): Sử dụng thuật toán AES-128 bit để mã hóa nội dung tin nhắn. Dữ liệu khi truyền đi trên đường truyền mạng LAN hoàn toàn là bản mã (Ciphertext), không thể đọc trực tiếp.

2. Xác thực người dùng (Authentication): Hệ thống yêu cầu đăng ký/đăng nhập. Dữ liệu tài khoản được lưu trữ dưới dạng đối tượng (Serialization), giúp bảo mật thông tin người dùng ngay cả khi server tắt.

3. Kiến trúc Đa luồng (Multi-threading): Server có khả năng xử lý đồng thời hàng chục Client và luồng Sniffer riêng biệt mà không gây nghẽn mạch logic.

13. Nguyên tắc hoạt động của hệ thống

1. Nguyên tắc hoạt động dựa trên mô hình Client-Server kết hợp với Intercepting (Đánh chặn) để mô phỏng tấn công.



14. Quy trình Chat an toàn (Client-to-Client)

1. Mã hóa tại nguồn: Khi người dùng A nhấn "Gửi", ứng dụng Client sẽ sử dụng khóa AES để mã hóa tin nhắn gốc thành chuỗi Ciphertext.

2. Truyền tải: Chuỗi Ciphertext được gửi qua Socket đến Server (Port 5000).

Xử lý tại Server: Server nhận chuỗi mã hóa, giải mã để xác định người nhận hoặc nội dung lệnh (như gửi file, chat nhóm), sau đó mã hóa lại và chuyển tiếp đến người nhận B.

3. Giải mã tại đích: Client của người nhận B nhận chuỗi Ciphertext, dùng khóa AES tương ứng để giải mã và hiển thị tin nhắn rõ ràng lên màn hình.





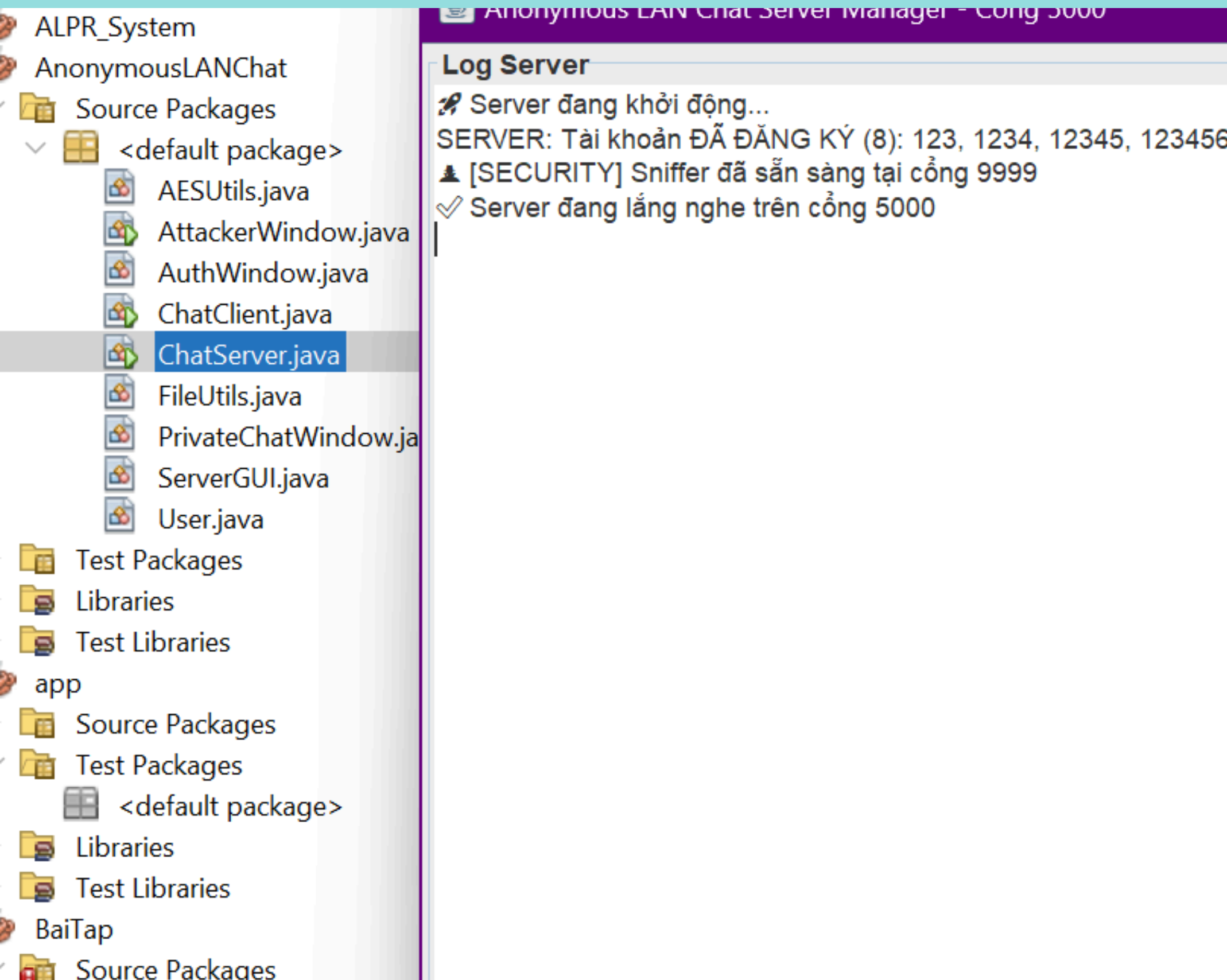
15. Nguyên tắc mô phỏng nghe lén (Phòng chống MITM)



1. Cổng Sniffer độc lập: Server mở một cổng riêng (Port 9999) dành cho các đối tượng muốn "nghe lén".
2. Cơ chế Copy dữ liệu: Mỗi khi có bất kỳ dòng dữ liệu nào đi qua Server (từ Client gửi lên hoặc Server phát ra), một hàm hỗ trợ (notifyAttackers) sẽ gửi một bản sao của dữ liệu đó tới cổng 9999.
3. Kết quả thu được: Đối tượng tấn công (Attacker) sẽ nhận được toàn bộ gói tin của hệ thống. Tuy nhiên, vì dữ liệu đã được mã hóa AES từ trước khi gửi đi, kẻ tấn công chỉ thấy các ký tự rác, không có giá trị thông tin.

10.DEMO

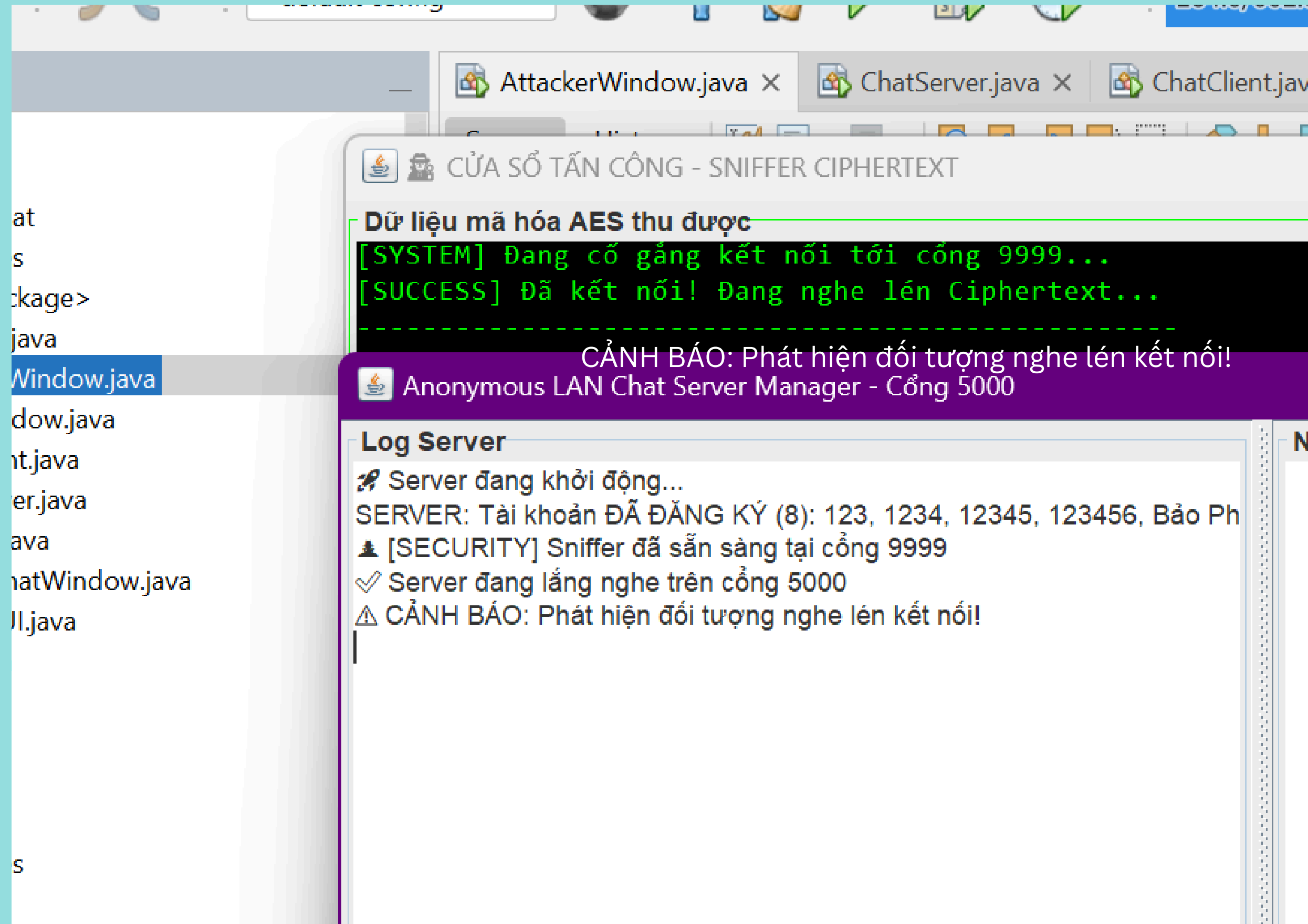
1. Khởi động hệ thống (Thiết lập phòng tuyến)



[SECURITY] Sniffer đã sẵn sàng tại cổng 9999.

Chứng minh hệ thống đã sẵn sàng cơ chế giám sát.

2. Phát hiện tấn công (Cảnh báo MITM)



CẢNH BÁO: Phát hiện đối tượng nghe lén kết nối!

Cho thấy hệ thống có khả năng phát hiện các hành vi xâm nhập trái phép vào luồng dữ liệu.

3.Chat an toàn giữa các Client (Dữ liệu rõ ràng)

Nickname: 123

✓**Đăng nhập thành công!** Bắt đầu trò chuyện với nickname: **123**

🕒 Thông báo từ Server: Người chơi **1234** đã tham gia phòng chat.

Bạn: HELO

123: 123: HELO

1234: 1234: HELO

Gửi

Đố vui

...

Nickname: 1234

✓**Đăng nhập thành công!** Bắt đầu trò chuyện với nickname: **1234**

123: 123: HELO

Bạn: HELO

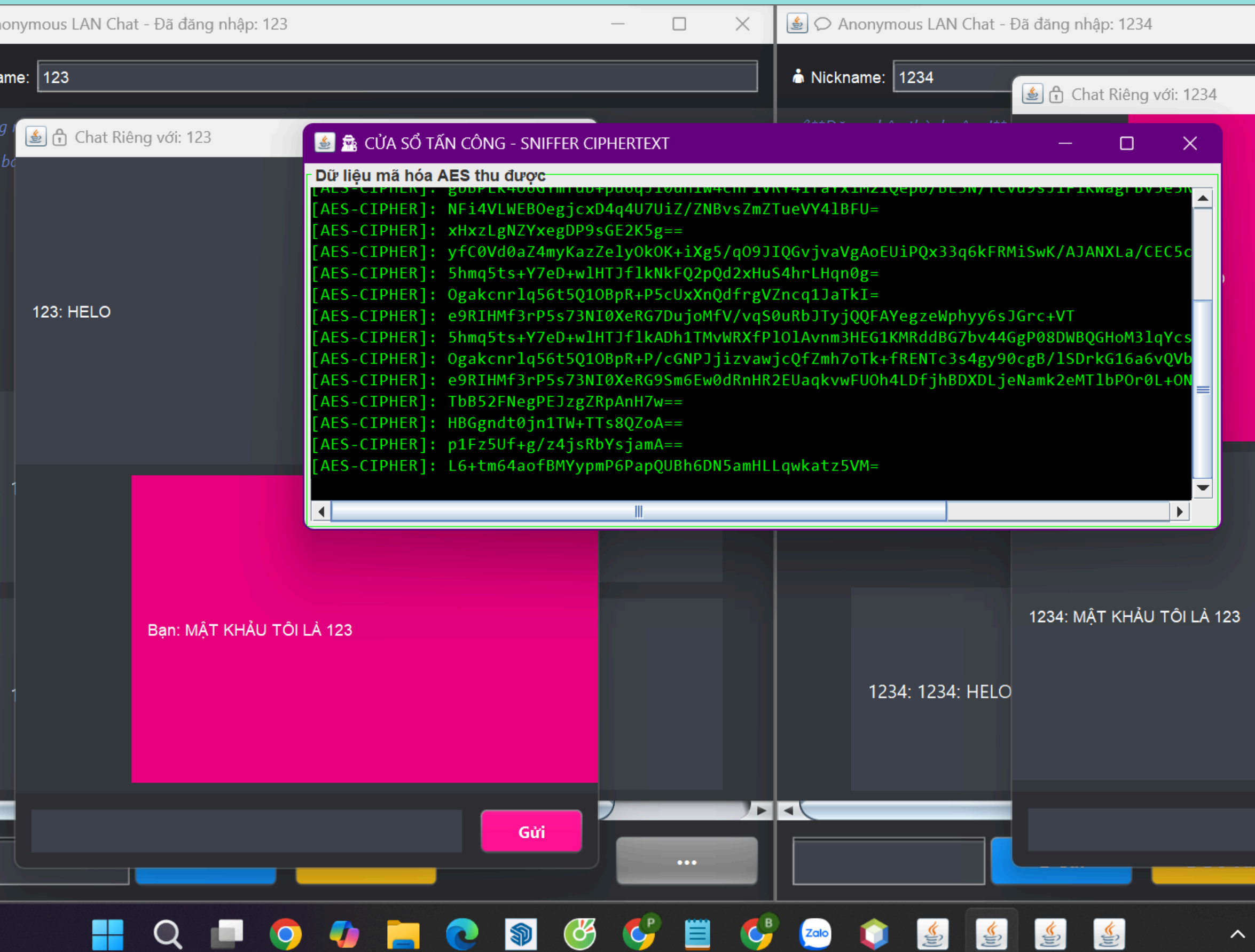
1234: 1234: HELO

Gửi

Đố vui

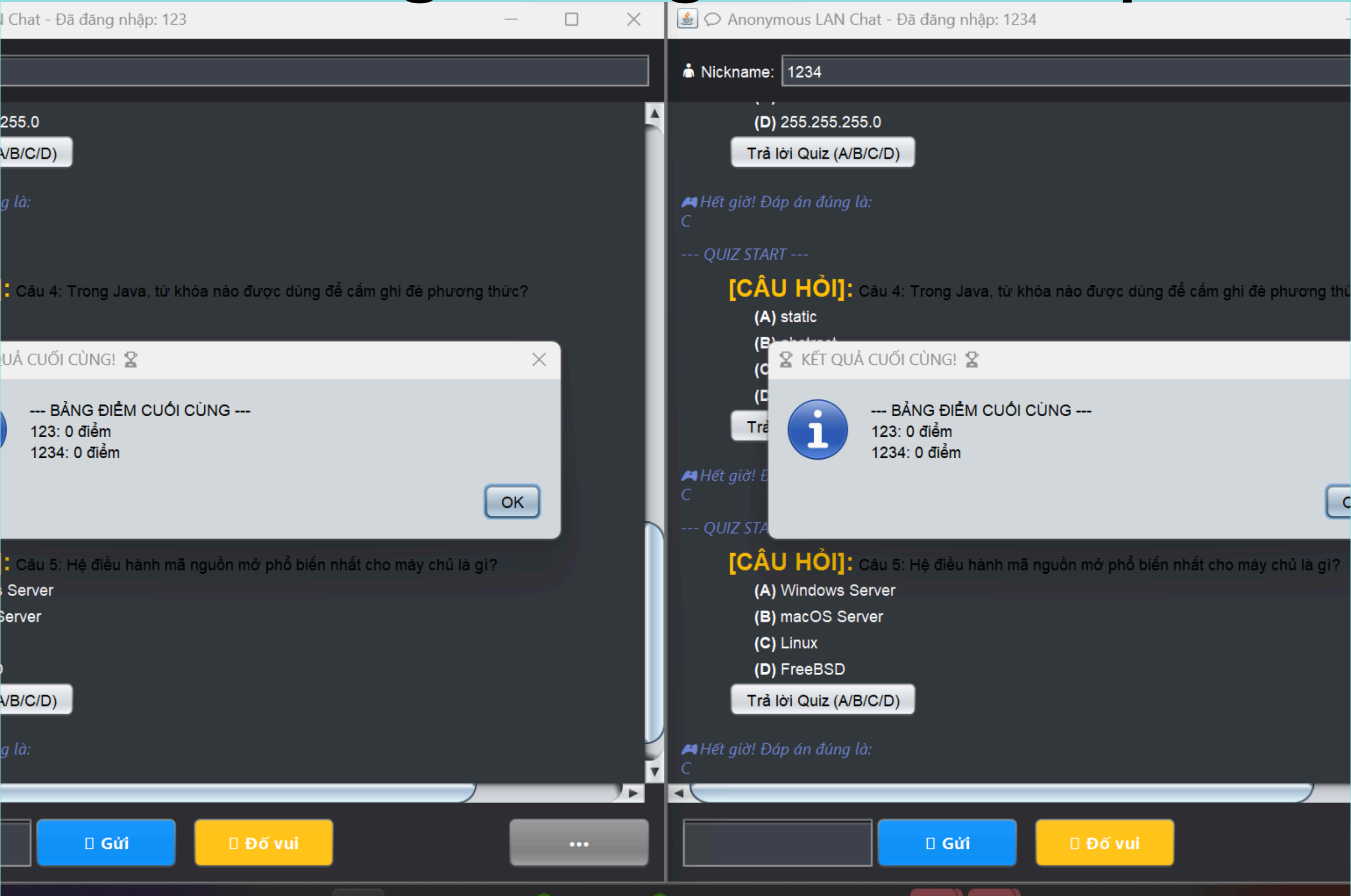
22
...

4. Kết quả đánh chặn của Kẻ tấn công (Bằng chứng bảo mật)

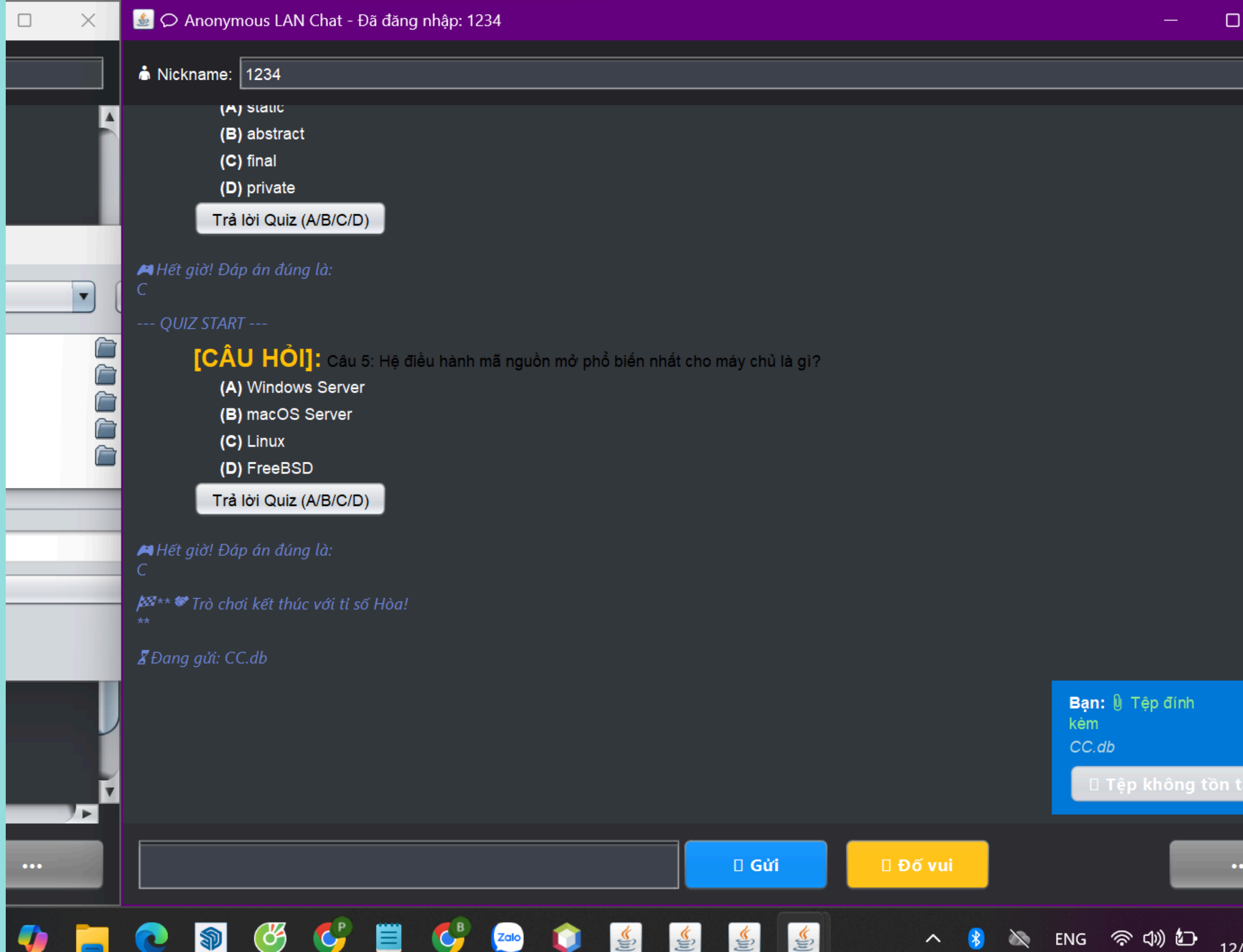


Chứng minh dù MITM thành công, kẻ tấn công cũng vô phương giải mã nội dung.

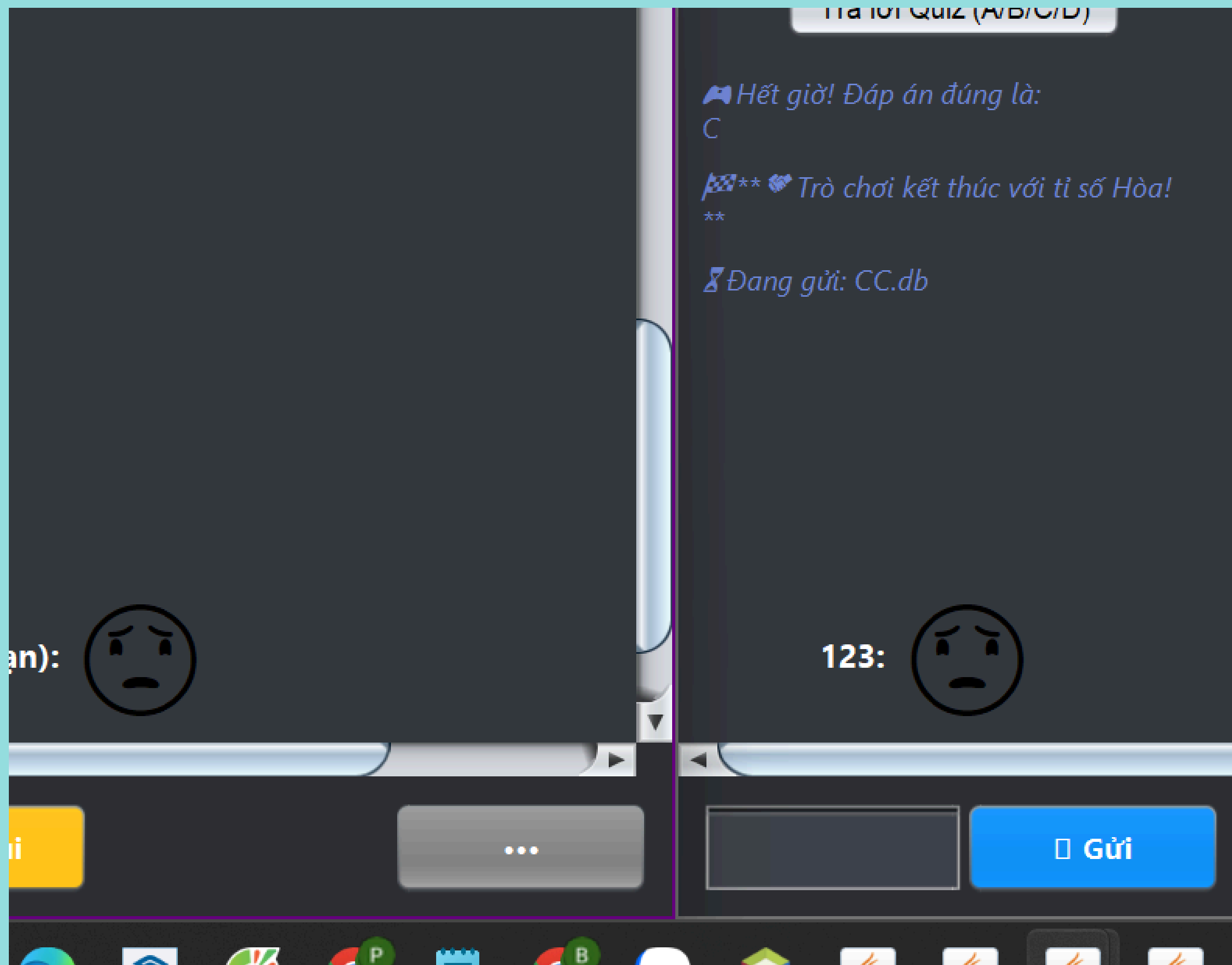
5.Tính năng bổ sung (Quiz & Group Chat)



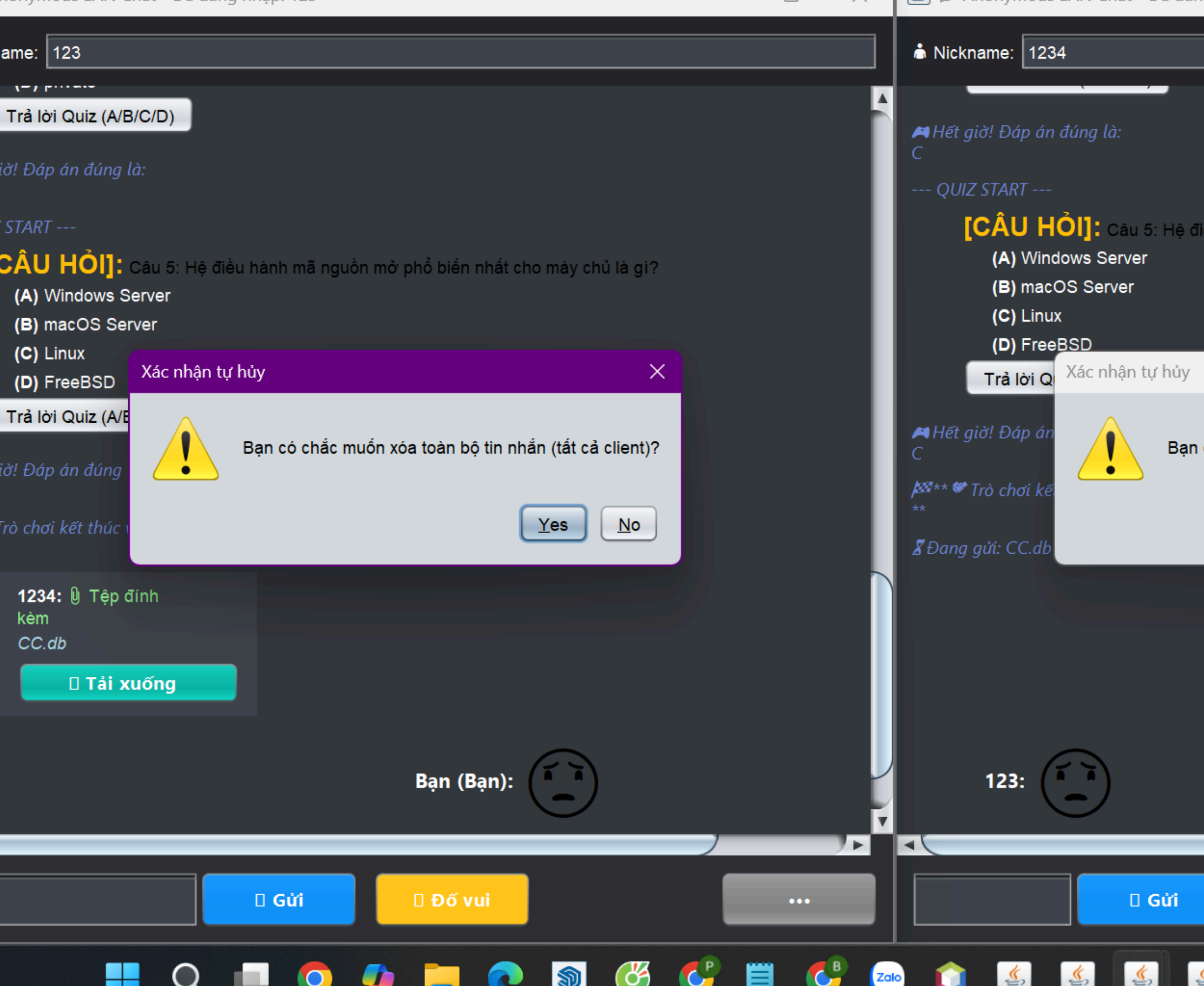
TRÒ CHƠI ĐO VUI



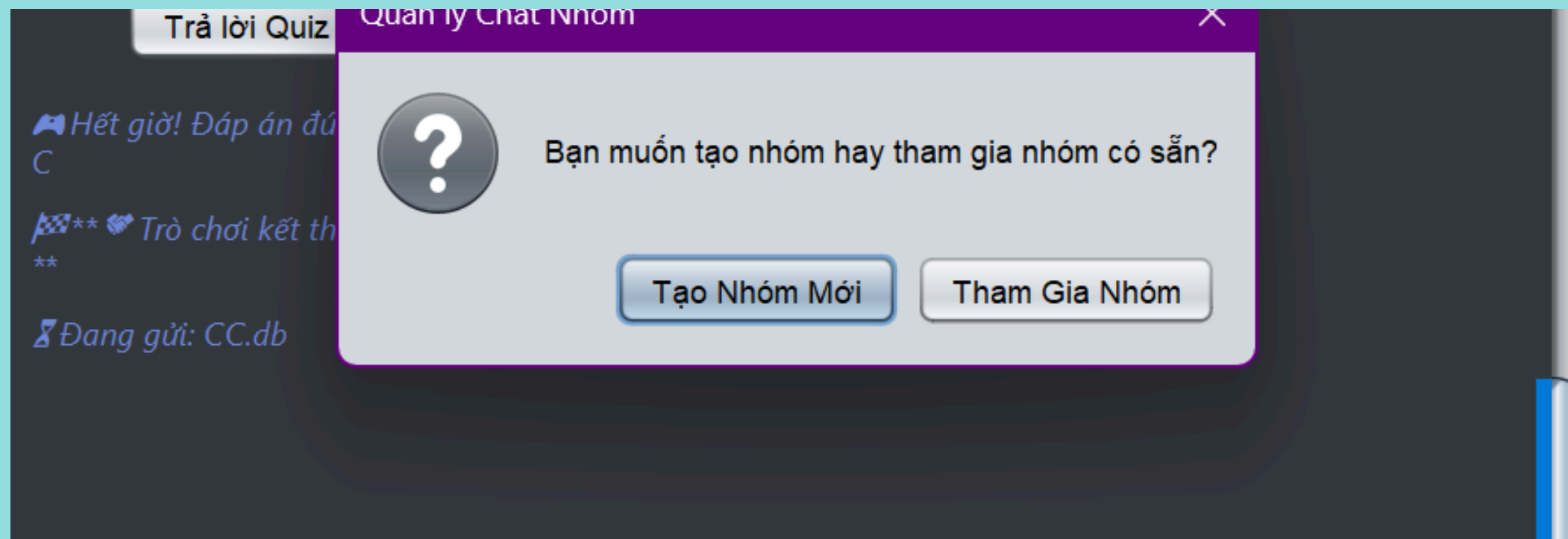
GỬI TỆP



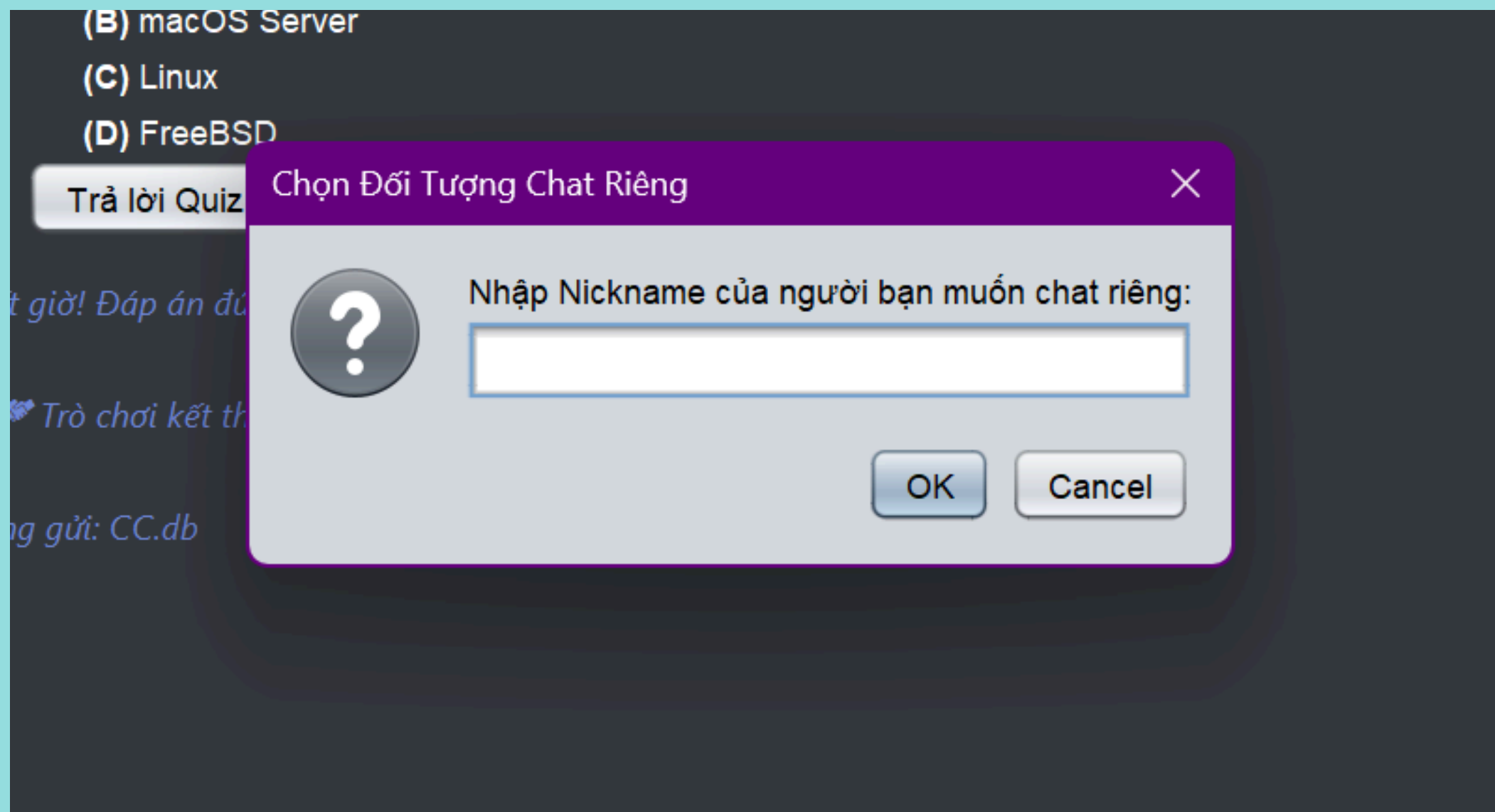
GỬI TICKER VUI NHỘN



CHUC NẮNG TỰ HỦY



CHỨC NĂNG CHAT NHÓM VÀ CHAT RIÊNG



Cho thấy ứng dụng đầy đủ tính năng, không chỉ mạnh về bảo mật mà còn tối ưu về trải nghiệm người dùng.

Kết luận:

"Đồ án đã khẳng định tầm quan trọng của việc mã hóa dữ liệu trong môi trường mạng nội bộ. Qua việc mô phỏng cuộc tấn công MITM, chúng ta thấy rằng mã hóa không chỉ là một tính năng, mà là lớp giáp bắt buộc để bảo vệ quyền riêng tư của người dùng trước những lỗ hổng bảo mật của hạ tầng mạng."